

Seguridad en Capa de Aplicación

La Capa 7 (Aplicación) En el modelo OSI, es la capa más alta y la que interactúa directamente con el usuario (navegadores web, apps móviles). Utiliza protocolos como HTTP/HTTPS, FTP o SMTP.

- **El Problema:** Los firewalls tradicionales (Capa 3 y 4) no detienen estos ataques porque operan sobre el puerto 80 o 443; para el cortafuegos, todo parece "tráfico normal".
- **La Solución:** Se requiere un WAF (Web Application Firewall) o, mejor aún, escribir código seguro.

2. OWASP (Open Web Application Security Project)

Es la fundación global que dicta el estándar de facto en seguridad de software. Mantienen el "**OWASP Top 10**", un ranking actualizado con las vulnerabilidades web más críticas y explotadas. Si programas, debes basarte en sus Cheat Sheets (guías de prevención).

3. Los Tres Vectores Principales del OWASP Top 10

1. Inyección SQL (SQLi):

- **Mecánica:** El programador confía en lo que el usuario escribe en un formulario de login o búsqueda. El atacante inserta código de base de datos directamente en el campo de texto.
- **Payload Clásico:** `' OR 1=1 --`. Esto engaña al código backend haciendo que la validación de la contraseña evalúe `1=1` (que siempre es verdadero), permitiendo el acceso sin la clave real.
- **Mitigación:** Nunca concatenar consultas SQL de forma directa; siempre se deben usar consultas parametrizadas y limpiar las entradas (sanitización).

2. XSS (Cross-Site Scripting):

- Mecánica: A diferencia del SQLi que ataca la base de datos (servidor), el XSS ataca a otros usuarios (cliente). El atacante inyecta un script malicioso (generalmente JavaScript) en una sección pública de la web (ej. caja de comentarios).
- Impacto: Cuando una víctima lee el comentario, su navegador ejecuta el código malicioso robándole sus cookies de sesión (secuestro de sesión).
- Mitigación: Escapar y codificar todas las variables de salida antes de mostrarlas en pantalla (convertir caracteres especiales a formato inofensivo HTML).

3. Broken Access Control (Pérdida de Control de Acceso):

- Mecánica: Los atacantes acceden a datos o funciones que no les corresponden saltándose la autorización.
- Ejemplo IDOR (Insecure Direct Object Reference): Iniciar sesión como usuario normal, notar que tu URL dice `perfil?id=10`, y cambiarlo manualmente a `id=1` para ver el perfil o los documentos del administrador.
- Mitigación: Validar siempre el token y los permisos de sesión del lado del servidor en cada petición, nunca confiar en la ID que envía el navegador.

4. Ecosistema Práctico (Herramientas del Oficio)

Para replicar y auditar estas fallas de Capa 7, pasamos del escaneo de red a la manipulación web:

1. **DevTools del Navegador (Nivel Básico):** Usar la consola (F12) para inyectar JavaScript en vivo y probar vectores XSS.
2. **VS Code / Sublime (Nivel Código):** Entornos ligeros para revisar el código fuente (PHP/Python) en busca de consultas no parametrizadas.
3. **Burp Suite (El Estándar Profesional):** Es un Proxy de Intercepción. Detiene la petición HTTP(S) justo cuando sale de tu navegador. El pentester modifica variables (inyecta SQL, manipula IDs, altera cookies) en el aire, y luego suelta la petición hacia el servidor para ver cómo reacciona.